

DD_API-00 - API Catalog and Gateway Standards

Version: v1.0

Status: Draft for review

Bundle: 00_index

Depends on:

- DD_CROSS-00-System_Traceability_and_Implementation_Map-v1.0
- FOUNDATION_AUTH
- FOUNDATION_KAFKA
- FOUNDATION_CACHE
- FOUNDATION_FILE_STORAGE

1. Purpose

This DD defines the API standards that all SOPHIX modules and frontend applications must follow.

It prevents each module from inventing different URL shapes, pagination, error responses, idempotency behavior, and gateway rules.

2. Scope

Included:

Area	Standard
URL naming	Consistent REST paths and versioning.
Auth	Bearer JWT and service-token rules.
Headers	Correlation, idempotency, operator context.
Pagination/filter/sort	Consistent query conventions.
Errors	Shared error response model.
OpenAPI	Publication and review process.
Gateway	Routing, rate limits, and frontend access rules.
BFF decision	When a backend-for-frontend is allowed.

3. API Ownership

Every API endpoint must have one owning module.

Endpoint type	Owner
Customer profile/account	ILM Customer Service
Ticket/case	TCK
Subscription master	SUB-LM
Subscription command	SUB-WF flow DD
Invoice/payment/wallet/dunning	BIL
Order capture	FUL-02
Work order	WO
Equipment/stock	OSR
Sales lead/territory	SALES
Reporting dashboard/export	REP
Files	FOUNDATION_FILE_STORAGE or owning module wrapper

Rule: frontend documents must link each screen action to an owning module endpoint.

4. URL And Versioning

Recommended pattern:

```
/api/{resource}
/api/{resource}/{id}
/api/{resource}/{id}/{sub-resource}
/api/admin/{resource}
```

Examples:

```
GET /api/customers/{id}
GET /api/subscriptions/{subscription_id}
POST /api/subscriptions/{subscription_id}/activate
GET /api/work-orders/{work_order_id}
POST /api/tickets/{ticket_id}/work-orders
GET /api/reports/dashboards/{dashboard_code}
```

Versioning:

- v1 internal contracts may use unversioned paths while DDs are still evolving.
- Before external or long-lived partner exposure, publish `/api/v1/ . . .`
- Breaking changes require a new version or backward-compatible field addition.

5. Required Headers

Header	Required when	Purpose
Authorization: Bearer <jwt>	User-facing APIs.	User identity and roles from FOUNDATION_AUTH.
X-Service-Token	Internal service-to-service APIs where configured.	Caller service identity.
X-Correlation-Id	All commands and important reads.	Trace request across modules/events.
Idempotency-Key	Create/command APIs that may be retried.	Prevent duplicate side effects.
X-Operator-Code	If not in path/body/token and endpoint is operator-scoped.	Operator scoping.
Accept-Language	Frontend calls.	Localized error/message hint where supported.

Rule: APIs must reject missing required auth headers with 401, missing required role with 403, and unsafe duplicate command according to the module idempotency rule.

6. Pagination, Filtering, Sorting

List APIs must be paginated.

Recommended query parameters:

```
page=0
size=50
sort=createdAt,desc
status=OPEN,ASSIGNED
operatorCode=WIK
from=2026-05-01
to=2026-05-28
```

Response shape:

```
{
  "items": [],
  "page": 0,
  "size": 50,
  "totalElements": 231,
  "totalPages": 5
}
```

Rules:

- Default size should be 20 or 50.
- Maximum size should be enforced by backend.
- Do not return unbounded operational lists.
- If a count is expensive, endpoint may return `hasNext` instead of exact totals, but this must be documented in OpenAPI.

7. Command Response Standard

Synchronous successful command:

```
{
  "status": "ACCEPTED",
  "entityId": "sub_01HY...",
  "operationId": "op_01J...",
  "correlationId": "corr_01J...",
  "nextAction": "TRACK_OPERATION"
}
```

Long-running workflow command:

```
{
  "status": "ACCEPTED",
  "operationId": "op_01J...",
  "processInstanceId": "camunda_123",
  "statusUrl": "/api/subscriptions/sub_01HY/operations/op_01J"
}
```

Rules:

- Do not return only "success": true for workflow commands.
- Return an operation id or status URL when work continues asynchronously.
- For idempotency replay, return the original result if the request hash matches.
- For same idempotency key with different request hash, return 409 IDEMPOTENCY_CONFLICT.

8. Error Response Standard

All module APIs should return:

```
{
  "errorCode": "SUBSCRIPTION_NOT_ACTIVE",
  "message": "Subscription is not active.",
  "correlationId": "corr_01J...",
  "retryable": false,
  "fieldErrors": [
    {
      "field": "subscriptionId",
      "code": "NOT_FOUND",
      "message": "Unknown subscription."
    }
  ],
  "nextAction": "CHECK_SUBSCRIPTION_STATUS"
}
```

HTTP status guidance:

Status	Use
200	Successful read or idempotent replay returning existing result.
201	Resource created synchronously.
202	Command accepted for async processing.
400	Invalid request syntax or validation.
401	Missing/invalid/expired token.
403	Authenticated but missing role/permission.
404	Resource not found or not visible to user.
409	Conflict: duplicate, invalid state, idempotency mismatch.
422	Business rule rejection where syntax is valid.
429	Rate limit.
500	Unexpected server error.
503	Dependency unavailable.

9. OpenAPI Catalog

Each module must publish an OpenAPI document before frontend implementation starts.

Required files:

```
api/openapi/{module-code}.openapi.yaml
```

Examples:

```
api/openapi/tck-01.openapi.yaml
api/openapi/sales-01.openapi.yaml
api/openapi/rep-01.openapi.yaml
```

Minimum content:

- paths and methods;
- request/response schemas;
- auth requirements;
- required headers;
- error responses;
- pagination model;
- idempotency behavior;
- examples matching DD samples.

10. Gateway Rules

Frontend apps call APIs through the approved gateway/base URL.

Gateway responsibilities:

Responsibility	Rule
TLS termination	Required.
Route to module services	Based on path/module route table.
Request size limits	Enforce; file uploads use file storage flow.
Rate limiting	Apply per user/client/IP where needed.
Correlation id	Generate if missing, preserve if present.
Auth passthrough	Do not strip bearer token before module auth.
CORS	Allow only approved frontend origins.

Gateway must not implement business rules that belong in modules.

11. BFF Policy

Default: frontend calls owning module APIs through the gateway.

A Backend-for-Frontend is allowed only when:

- a screen requires many module reads and latency becomes unacceptable;
- the BFF is read-composition only, or its command simply delegates to one owning module;
- the BFF does not create new hidden ownership;
- the BFF contract is documented in OpenAPI;
- module source ownership is visible in the frontend DD.

Recommended BFF candidates:

Candidate	Reason
Customer 360 read composition	Many panels from many modules.
Global search	Federated search across modules.
Backoffice home dashboard	Many queue summaries.

Not allowed:

- BFF writes directly to module databases;

- BFF changes business status owned by another module;
- BFF hides which module owns the action.

12. File APIs

Files must use FOUNDATION_FILE_STORAGE.

Rules:

- frontend should upload through authorized upload/init APIs;
- business module stores file metadata/reference where it owns attachment lifecycle;
- direct public object URLs are not allowed for protected documents;
- downloads must be authorized and audited where required.

13. Implementation Checklist

- [] Endpoint has one owning module.
- [] OpenAPI exists.
- [] Auth and role guard documented.
- [] Required headers documented.
- [] Pagination/filter/sort documented for lists.
- [] Idempotency behavior documented for commands.
- [] Error responses follow shared model.
- [] Frontend DD maps screen/action to this endpoint.
- [] Contract tests exist.